

Grille d'audit croisé — Contrat OpenAPI

Commission d'architecture — Séance 9

Groupe auditeur : Groupe 1 Contrat audité (Groupe X) : Groupe 4 Créneau : _____
(20 min d'audit · 5 min de restitution à 11h45)

Chaque groupe réalise **2 audits** sur la journée (20 min chacun). Vous ne remettez qu'**une seule fiche** avant 11h45 — celle qui produit le retour le plus solide. La restitution orale porte sur cette fiche retenue. **½ page de rendu** — soyez concis et factuels.

Grille d'évaluation rapide

Pour chaque critère, cochez le niveau observé et notez un commentaire factuel (1-2 lignes max).

Critère 1 — Endpoint testable sans lire le code

Peut-on construire une requête valide sur au moins un endpoint en lisant uniquement le contrat ?

- ☒ **Oui** — Le contrat suffit (URL, méthode, paramètres, authentification)
- ☐ **Partiel** — Des informations manquent (ex. format d'authentification non précisé)
- ☐ **Non** — Impossible sans aide extérieure

Commentaire : _____

Critère 2 — Erreurs 4xx et 5xx documentées

Les réponses d'erreur sont-elles décrites (code HTTP, corps de réponse, signification) ?

- ☐ **Oui** — Au moins les principales erreurs sont documentées avec corps structuré
- ☒ **Partiel** — Seulement certains endpoints ou seulement les codes sans corps
- ☐ **Non** — Uniquement les cas 200/201 documentés

Commentaire : Que les codes par défaut, il y a qu'un cas de réussite et un d'erreur pour chaque endpoint

Critère 3 — Stratégie de versioning visible

Peut-on identifier la version de l'API et comprendre la stratégie adoptée ?

- ☐ **Oui** — Versioning visible (URL, header) et expliqué
- ☒ **Partiel** — Version présente mais stratégie non explicitée
- ☐ **Non** — Aucun versioning identifiable

Commentaire : Présente côté serveur mais pas la stratégie explicite sur le contrat. Identifiable dans les doc du projet

Critère 4 — Exemples présents

Y a-t-il des exemples de requête et/ou de réponse dans le contrat ?

- ☒ **Oui** — Exemples présents pour les endpoints principaux
- ☐ **Partiel** — Quelques exemples, non systématiques
- ☐ **Non** — Aucun exemple

Commentaire : _____

Critère 5 — Cohérence des schemas

Les types, formats et contraintes (**required**, **type**, **format**, **enum**) sont-ils définis de façon cohérente ?

- ☒ **Oui** — Schemas complets et cohérents entre endpoints
- ☐ **Partiel** — Quelques schemas incomplets ou incohérents
- ☐ **Non** — Schemas absents ou très lacunaires

Commentaire : _____.

Critère 6 — README opérationnel

Le README permet-il de démarrer le projet sans contacter l'équipe ?

- ☒ **Oui** — Variables d'environnement, commandes de démarrage, prérequis couverts
- ☐ **Partiel** — L'essentiel est là mais des étapes sont implicites
- ☐ **Non** — README absent, vide, ou insuffisant pour démarrer

Commentaire : _____

Critère 7 — Cohérence endpoints / ressources

Les endpoints exposés forment-ils un ensemble cohérent ? (nommage uniforme, logique REST respectée)

- ☐ **Oui** — Nommage et structure cohérents, verbes HTTP appropriés
- ☒ **Partiel** — Quelques incohérences isolées
- ☐ **Non** — Incohérences significatives (nommage mixte, verbes mal utilisés, structure cassée)

Commentaire : Tout est cohérents pour les routes mais ça devient verbeux et tout aux pluriels alors que certaines routes sont pour un cas.

Critère 8 — Sécurité visible dans le contrat

Les endpoints sensibles documentent-ils l'authentification requise (securitySchemes, security) ?

- ☒ **Oui** — Schéma de sécurité défini et appliqué aux endpoints concernés
- ☐ **Partiel** — Présent pour certains endpoints seulement
- ☐ **Non** — Aucune information de sécurité dans le contrat

Commentaire : _____

Synthèse (à compléter pour la restitution à 11h45)

Point fort identifié

(Ce que ce contrat fait bien — soyez précis)

La partie identification des rôles très claires et information facile à retrouver.

Incohérence ou manque identifié

(1 point concret, avec référence à l'endpoint ou à la section concernée)

Manque de diversification dans les codes d'erreurs. Seulement 2 codes d'erreurs pour chaque routes.

Question ouverte pour le groupe audité

(Ce que vous aimeriez leur demander pendant la restitution)

Consignes de restitution (11h45, 5 min max par groupe)

Structure imposée pour votre restitution orale :

1. **1 point fort** : ce que ce contrat fait mieux que la moyenne — avec un exemple précis.
2. **1 incohérence ou manque** : ce que vous avez trouvé, avec la référence dans le contrat.
3. **1 question ouverte** : posée directement au groupe audité (ils ont 1 minute pour répondre).

Rappel : L'audit est formatif. L'objectif n'est pas de noter, mais de donner un retour utile. Soyez factuels, pas rhétoriques.